

TAREA BRS07

Configuración de dispositivos y sistemas informáticos II

Autor: Carlos España Del Pozo - CETI

Contenido

Apartado 1.....	3
Respuesta 1	4

Apartado 1

Desde hace unos días no paramos de recibir incidentes de seguridad en el SOC. Tenemos 2 incidentes nuevos que resolver. Uno relacionado con una denegación de servicio distribuido y otro relacionado con un ataque a la web de la compañía.

Nos han enviado la información recopilada en el análisis del incidente de DDoS (Denegación de Servicio Distribuida). Tenemos que ordenar la información para buscar desde qué ISPs viene el ataque para informar a nuestro SOC, y pueda tomar las acciones oportunas con los ISP de país sobre las IPs detectadas, y pueda cortar el ataque desde el origen (fichero - datos conexiones (.dat - 53000 KB)).

Con esta información, además podremos aplicar las contramedidas necesarias y disminuir el impacto del ataque.

Para realizar el ataque puede utilizar comandos de Linux con una máquina Linux o instalando Cygwin en una máquina Windows: cat, grep, head, tail, sort, cut, awk, netcat o automatizarlo con python.

El ataque se ha producido por UDP y los campos relativos a los logs recibidos tienen el siguiente formato:

Columna	Descripción
1	Fecha
2	Hora
3	Duración
4	Protocolo
5	IP:puerto origen
6	->
7	IP:puerto destino
8	Nº paquetes transmitidos
9	Nº bytes transmitidos
10	Número de flujo

Héctor Fernández Bardal. Tabla datos ejercicio [CCO](#)

Necesitamos:

Tener un listado de IPs únicas

Su geolocalización con un servicio de whois

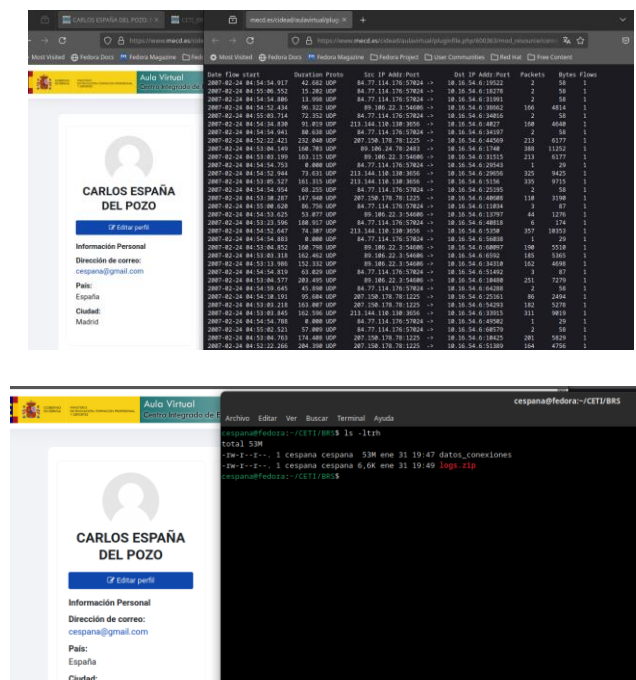
Relativo al ataque web, debemos identificar (fichero logs.zip (zip - 6,41 KB)):

- Las herramientas ofensivas utilizadas por los atacantes
- Las páginas web sobre las que han realizado el ataque
- Usuarios utilizados en cada uno de los servicios atacados
- Ficheros descargados

Para estas tareas se proporcionarán ficheros de registros (logs) de los que es necesario extraer la información al que se ha hecho referencia anteriormente.

Respuesta 1

Primero de todo descargaremos los ficheros facilitados y los guardamos en nuestro entorno Fedora Linux.



Tendremos los datos de los dos ejercicios:

```
datos_conexiones
logs.zip
```

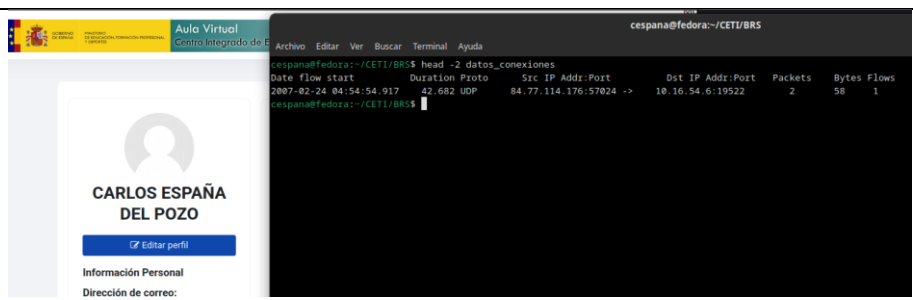
1. Ataque DDOS

1.1 Listado de Ip's Unicas

Para sacar un listado de ips únicas del primer fichero facilitado, lo primero es ver en que campo podemos ver las IPs de origen.

Para ello ejecutaremos el siguiente comando:

```
head -2 datos_conexiones
```



Una vez sabemos que la información necesaria está en el campo número cinco, realizaremos una combinación de comandos para realizar el filtrado y la salida la redireccionamos a un fichero para tratar dicha información.

```
cat datos_conexiones |awk '{print $5}' |grep -v Proto |awk -F ":" '{print $1}' |sort |uniq >
IPS_DDOS_BR07.log
```

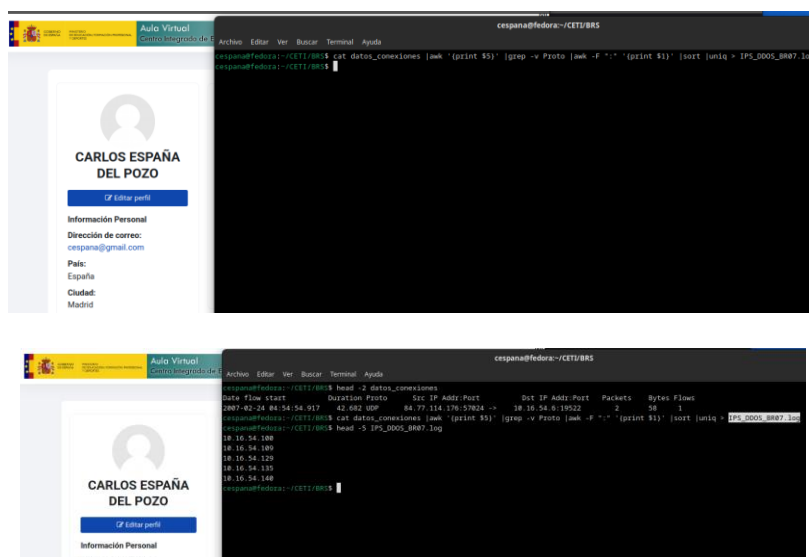
Cat -> visualizar datos

Awk -> filtrar campos

Grep -v -> eliminar datos de salida

Awk -> filtrado segundo seleccionando un campo diferente

Sort y uniq -> filtrado único de datos finales

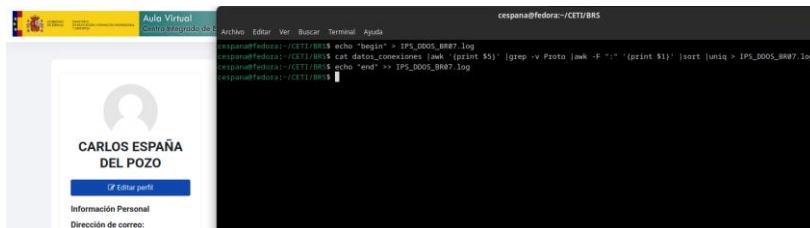


1.2. Geolocalización de Ip's únicas

Para ello utilizaremos el comando que "whois" para ello, seguiremos la documentación facilitada de "Team Cymru"

Añadimos al principio de nuestro fichero "begin" y al final "end"

```
echo "begin" > IPS_DDOS_BR07.log
cat datos_conexiones |awk '{print $5}' |grep -v Proto |awk -F ":" '{print $1}' |sort |uniq >>
IPS_DDOS_BR07.log
echo "end" >> IPS_DDOS_BR07.log
```

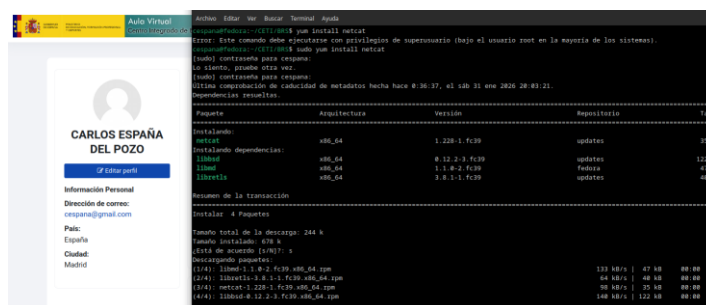


Y finalmente ejecutamos el comando netcat consultando a whois.cymru.com

```
nc whois.cymru.com 43 < IPS_DDOS_BR07.log
```

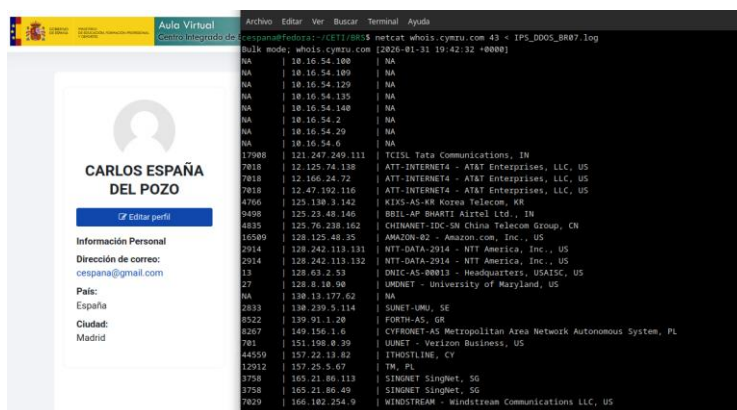
Este comando no nos muestra nada y por lo tanto vamos a descargar el nc de GNU: “netcat”

```
yum install netcat
```



Ahora si, ejecutaremos:

```
netcat whois.cymru.com 43 < IPS_DDOS_BR07.log
```



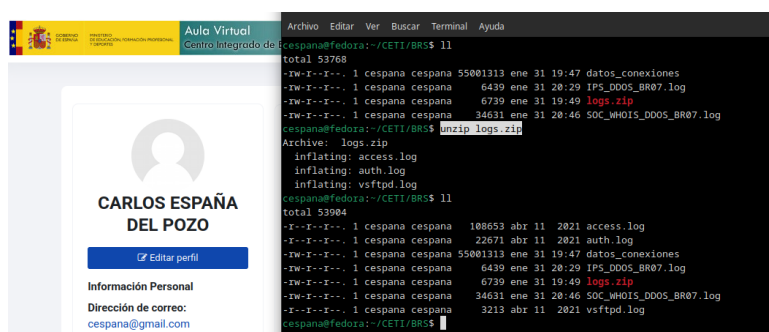
Ahora podemos trasladar a un fichero y facilitárselo al SOC

```
netcat whois.cymru.com 43 < IPS_DDOS_BR07.log > SOC_WHOIS_DDOS_BR07.log
```

3. Ataque WEB

Primero de todo descomprimiremos el LOG

```
unzip logs.zip
```

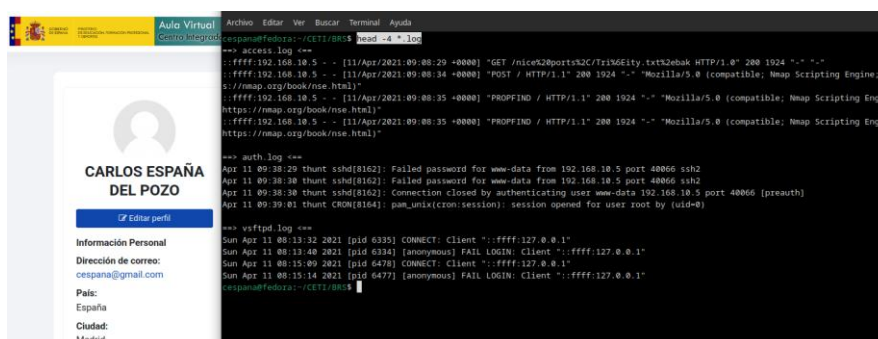


Y tenemos los siguientes ficheros para analizar:

```
access.log
auth.log
vsftpd.log
```

Una vez tenemos los tres ficheros logs, revisaremos la información que podemos obtener de cada uno de ellos con el comando:

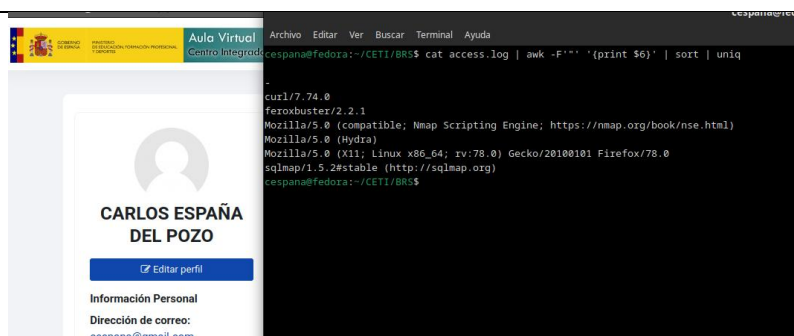
```
head -4 *.log
```



3.1 Las herramientas ofensivas utilizadas por los atacantes

En este caso podemos observar que los datos del archivo Access.log nos puede valer para sacar este dato:

```
cat access.log | awk -F'"' '{print $6}' | sort | uniq
```



Cat -> visualizar datos

Awk -> filtrar campos con separador específico

Sort y uniq -> filtrado único de datos finales

Aquí podemos ver las diferentes herramientas ofensivas utilizadas:

nmap

Sqlmap

feroxbuster

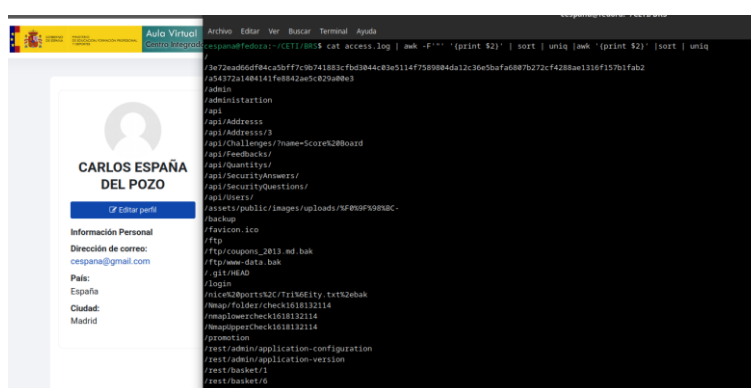
Curl

Hydra

3.2 Las páginas web sobre las que han realizado el ataque

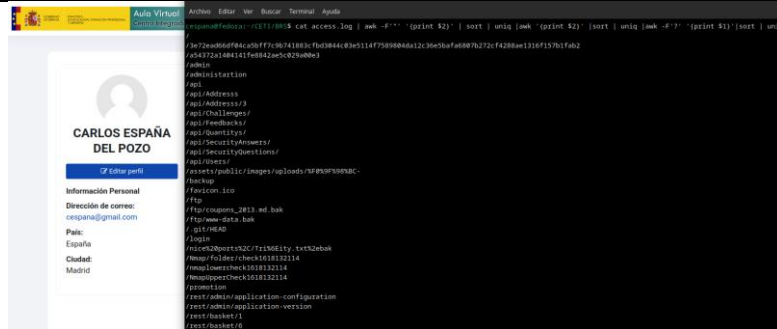
Los datos del archivo Access.log también nos puede valer para sacar este dato:

```
cat access.log | awk -F'"' '{print $2}' | sort | uniq | awk '{print $2}' | sort | uniq
```



Podemos filtrar algo mejor con:

```
cat access.log | awk -F'"' '{print $2}' | sort | uniq | awk '{print $2}' | sort | uniq | awk -F'"' '{print $1}' | sort | uniq
```

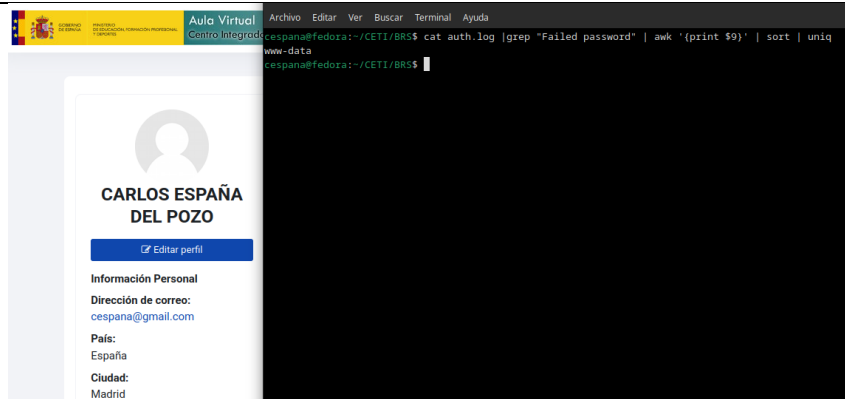


3.3 Usuarios utilizados en cada uno de los servicios atacados

Aquí nos centraremos en el archivo auth.log y vsftpd.log para visualizar los usuarios que han sido atacados:

- En el auth.log

```
cat auth.log | grep "Failed password" | awk '{print $9}' | sort | uniq
```



Cat -> visualizar datos

grep -> filtrar por datos

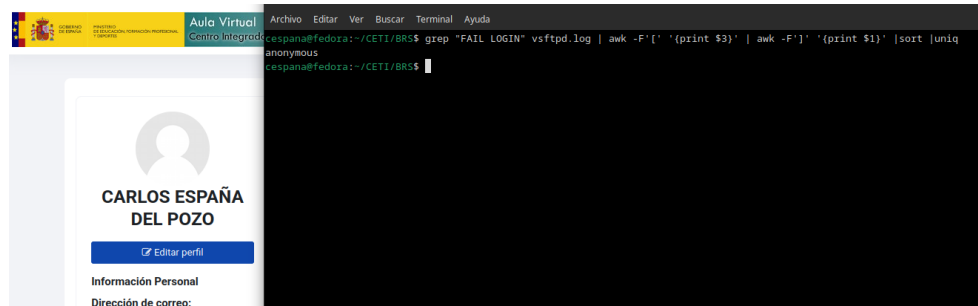
Awk -> filtrar campos

Sort y uniq -> filtrado único de datos finales

Vemos que el usuario que ha sido atacado es **www-data** (usuario de apache)

- En el vsftpd.log

```
grep "FAIL LOGIN" vsftpd.log | awk -F'"' '{print $3}' | awk -F'"' '{print $1}' | sort | uniq
```

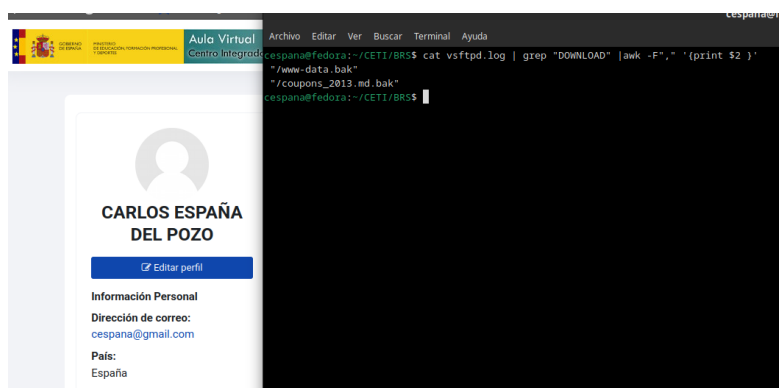


Vemos que el usuario utilizado ha sido "Anonymous"

3.4 Ficheros descargados

Para finalizar vamos a intentar ver que posibles ficheros se han descargado para ello volveremos a utilizar el fichero vsftpd.log con el siguiente comando:

```
cat vsftpd.log | grep "DOWNLOAD" |awk -F"," '{print $2 }'
```



Podemos observar que se han descargado dos ficheros:

"/www-data.bak"

"/coupons_2013.md.bak"